

CHAPTER 6.4: ANONYMOUS COMMUNICATION

FOUNDATIONS OF DISTRIBUTED SYSTEMS

Isabel Wagner

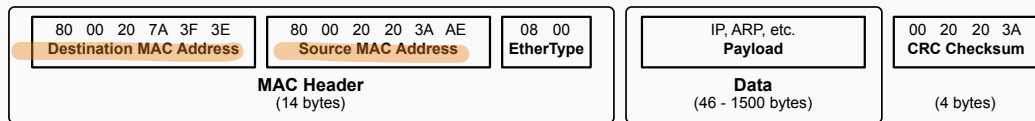
Fall semester 2025

University of Basel

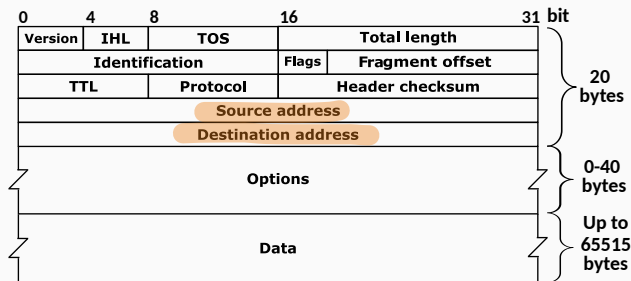
1. Anonymous communication
2. Dining cryptographers
3. Crowds
4. Mix networks
5. Onion routing
6. Privacy-preserving authentication

1. ANONYMOUS COMMUNICATION

WHY IS ENCRYPTION NOT ENOUGH?



Ethernet Type II Frame
(64 to 1518 bytes)



IPv4 Packet

Identifiers in communication protocols are enough to identify individuals

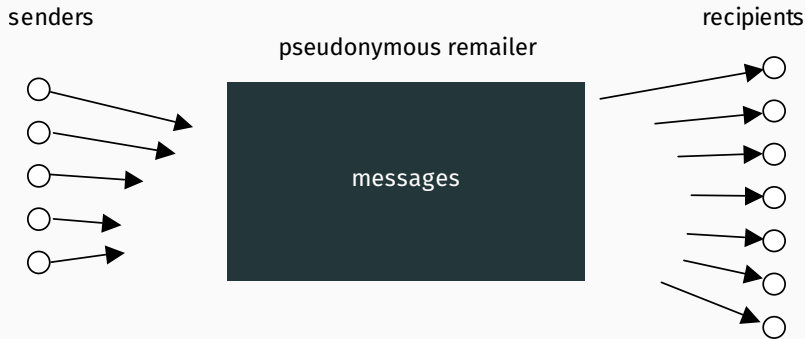
SETTINGS & GOALS FOR ANONYMOUS COMMUNICATION¹

- We want to communicate with others, while ensuring not only confidentiality of messages, but also:
- Sender anonymity
 - Adversary (including receiver) cannot identify who the sender is
- Receiver anonymity
 - Adversary (including sender) cannot identify who the receiver is
- Bidirectional anonymity
 - Adversary cannot identify who the sender and receiver are
- Unobservability
 - Adversary cannot tell if users send or receive messages
- Unlinkability
 - Messages cannot be linked to users

¹A. Pfitzmann and M. Hansen, "A terminology for talking about privacy by data minimization: Anonymity, Unlinkability, Undetectability, Unobservability, Pseudonymity, and Identity Management," Tech. Rep., Aug. 2010. [Online]. Available: http://dud.inf.tu-dresden.de/literatur/Anon_Terminology_v0.34.pdf.

NAIVE APPROACH: PSEUDONYMOUS REMAILER

- Single server, strips technical information from emails and resends them using anonymous aliases
- For two-way communication: keeps mapping from real user emails to aliases
- Real-world example: Penet remailer 1993–1996²



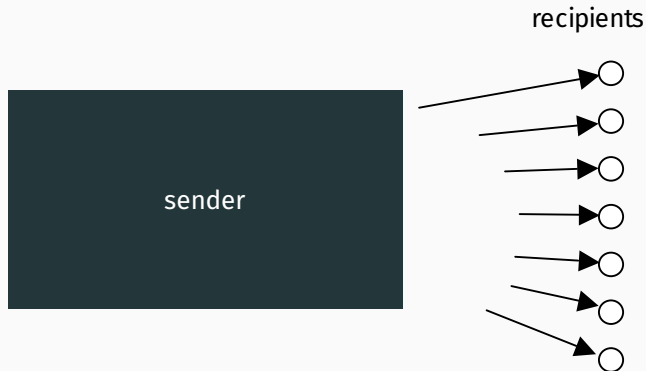
²https://en.wikipedia.org/wiki/Penet_remailer

- Throughput does not scale
- What if remailer is corrupt?
- What if remailer is coerced to reveal the internal mapping?
 - This has happened at least twice with Penet
 - Church of Scientology obtained a search warrant because someone posted a stolen file to a newsgroup

ANOTHER NAIVE APPROACH: BROADCAST

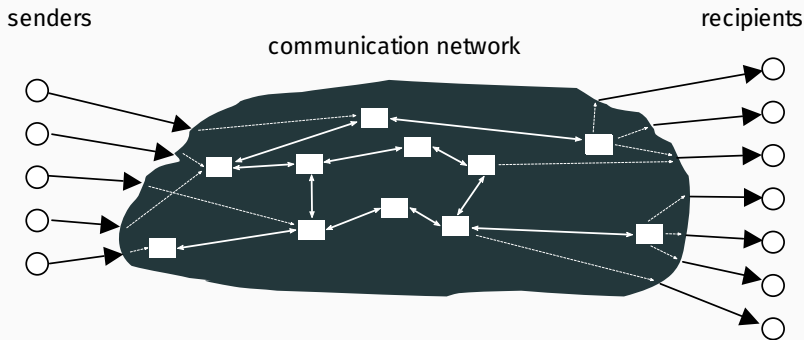
- Alice broadcasts an encrypted message
- Only the designated receiver has the correct key to decrypt it
- Receiver anonymity!

- But...
 - Sender anonymity?
 - Bandwidth usage?
 - Resource use on receiver side?



BETTER APPROACH: ANONYMOUS COMMUNICATION NETWORK

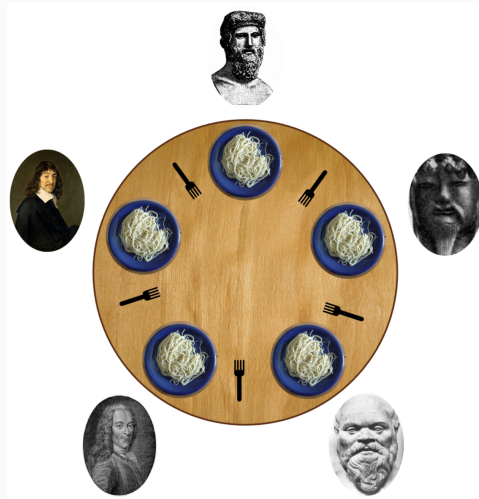
- Many independent servers who repacketize, reschedule, reroute
- Large design space for specific systems:
 - Desired anonymity properties?
 - How many servers, who operates them?
 - Assumptions about adversary?
 - Data streams vs messages? Bandwidth vs delay?



- Dining cryptographer networks
- Crowds
- Mix networks
- Onion routing

2. DINING CRYPTOGRAPHERS

- When philosophers dine, the problem is starvation (deadlock caused by concurrent access to forks)
- When cryptographers dine, the problem is to find out whether one of the cryptographers paid, or the NSA!

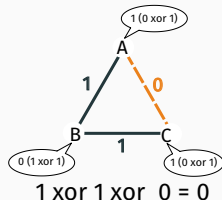


Source: https://commons.wikimedia.org/wiki/File:An_illustration_of_the_dining_philosophers_problem.png

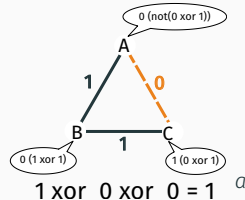
DINING CRYPTOGRAPHERS²

- 3 cryptographers at dinner
- Each pair of cryptographers establishes a shared secret, e.g., by flipping a coin behind a menu
- Each cryptographer publicly announces:
 - If they didn't pay: the XOR of the two shared bits
 - If they did pay: the opposite of that XOR

None paid



A paid

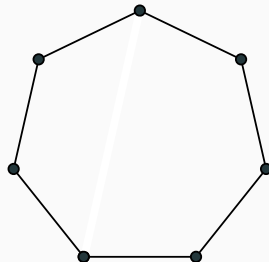
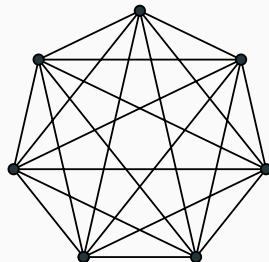


^aImage source:

https://commons.wikimedia.org/wiki/File:Dining_Cryptographers.svg

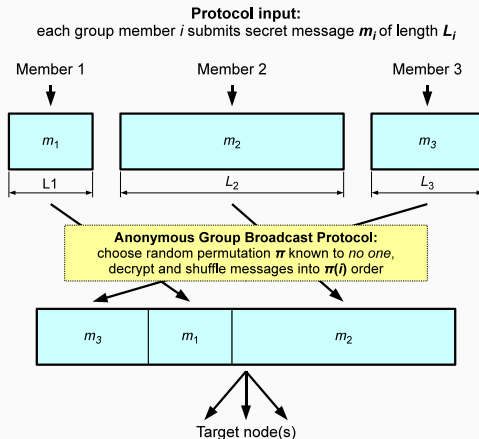
- What happened in the 3-cryptographers example?
- The person who paid (if any) communicates the bit value 1 to the group
- To send large messages: we can repeat the protocol, 1 bit per round
- To get the shared secret each round: use stream cipher with pre-agreed shared master secret

- Option 1: fully-connected graph, shared secret between each pair of participants
 - Does not scale well!
 - n broadcasts per message
- Option 2: ring topology
 - Appealing: only 2 shared secrets for each participant, not n
 - Adversaries surrounding a participant can break anonymity
 - Adversaries can partition the graph to reduce anonymity set size



- Anonymity properties: sender and receiver anonymity
- Servers: no dedicated infrastructure
- Adversary:
 - Internal adversaries can break anonymity when graph is not fully connected, specifics depend on topology
 - Internal adversaries can jam the protocol (denial of service) by transmitting random bits
- Performance:
 - Depends on the topology
 - But generally, communication cost scales with number of participants
 - Assumption: all users always available

DC NETWORKS IN THE 2010S: DISSENT³



Protocol output:
send all members' messages to target(s) in shuffled order

³H. Corrigan-Gibbs and B. Ford, "Dissent: Accountable anonymous group messaging," in *Proceedings of the 17th ACM Conference on Computer and Communications Security*, ser. CCS '10, Chicago, IL, USA: Association for Computing Machinery, Oct. 2010, pp. 340–350. DOI: 10.1145/1866307.1866346. [Online]. Available: <https://dl.acm.org/doi/10.1145/1866307.1866346>.

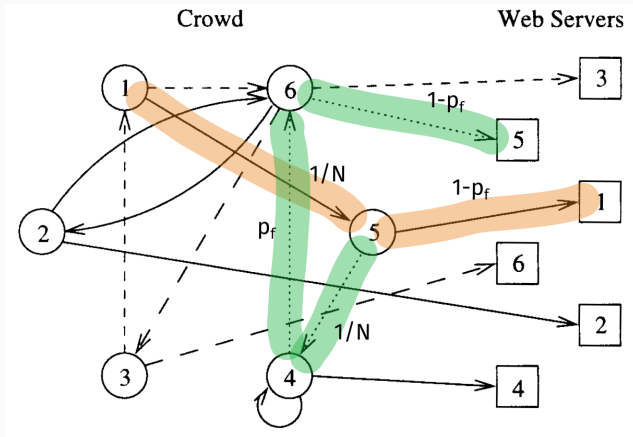
3. CROWDS

- Problem: how to anonymously browse the web, i.e., how to provide sender anonymity to web users
- Key ideas:
 - Group users into diverse groups (crowds)
 - The group issues requests to web servers on behalf of users
 - Group members collaborate by forwarding requests of other users

⁴M. K. Reiter and A. D. Rubin, "Crowds: Anonymity for web transactions," *ACM Transactions on Information and System Security (TISSEC)*, vol. 1, no. 1, pp. 66–92, 1998. [Online]. Available: <http://dl.acm.org/citation.cfm?id=290168>.

CROWDS: OPERATION⁵

- User 1: select member of the crowd with probability $1/N$
- User 5: forward to the crowd with probability p_f (select member with $1/N$), or forward to web server with $1 - p_f$
- Web server cannot tell whether/how often the request has been forwarded



⁵M. K. Reiter and A. D. Rubin, "Crowds: Anonymity for web transactions," *ACM Transactions on Information and System Security (TISSEC)*, vol. 1, no. 1, pp. 66-92, 1998. [Online]. Available: <http://dl.acm.org/citation.cfm?id=290168>.

Attacker	Sender anonymity
local eavesdropper	exposed
c collaborating members, $n \geq (p_f / (p_f - 1/2))(c + 1)$	probable innocence $P(\text{absolute privacy}) \xrightarrow[n \rightarrow \infty]{} 1$
end server	beyond suspicion

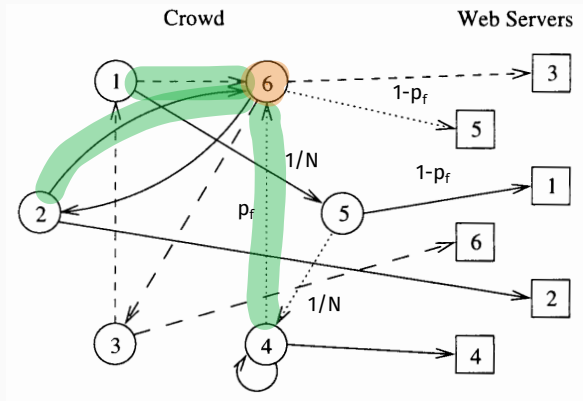
- Beyond suspicion: sender is no more likely than any other potential sender
- Probable innocence: sender may be more likely than other senders, but their being sender is as likely as their not being sender
- Note: Crowds does not encrypt metadata → messages are at least partially sent in the clear!

- Assumptions
 - Protocol selects paths at random
 - Paths may change over time
 - Multiple messages form a session and the messages contain some information about the session (e.g., cookies, IP addresses, login names)
 - The adversary can see session information and (sometimes) observe the initiator sending
- In Crowds:
 - Adversary is a crowd member
 - Paths are reformed periodically when new members join (batched, configurable intervals, e.g., hourly)

⁶M. Wright, M. Adler, B. N. Levine, et al., "An Analysis of the Degradation of Anonymous Protocols," in *Network and Distributed System Security Symposium (NDSS)*, vol. 2, San Diego, CA, USA, Feb. 2002, pp. 39–50. [Online]. Available: <http://forensics.umass.edu/pubs/wright.ndss01.pdf>.

PREDECESSOR ATTACK⁷

- After each round (path reformation): adversary observes the predecessor for each request
- Which node is most likely to be part of a path?



⁷M. Wright, M. Adler, B. N. Levine, et al., "An Analysis of the Degradation of Anonymous Protocols," in *Network and Distributed System Security Symposium (NDSS)*, vol. 2, San Diego, CA, USA, Feb. 2002, pp. 39–50. [Online]. Available: <http://forensics.umass.edu/pubs/wright.ndss01.pdf>.

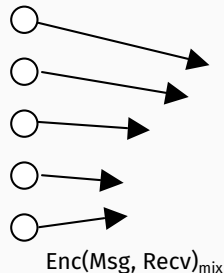
- After each round (path reformation): adversary observes the predecessor for each request
- Among all crowd members, the initiator has the highest probability to be part of a path
 - Over many rounds, adversary counts how often it sees each node as its predecessor
 - The most frequent node is most probably the initiator
- The predecessor attack is not Crowds-specific: it works for *any protocol that meets the assumptions!*

- Anonymity properties: sender anonymity
- Servers: operated by users
- Adversary:
 - Internal adversaries can break anonymity (predecessor attack)
 - Internal adversaries can deny service by refusing to forward requests
- Performance:
 - Potentially long paths can lead to long latency
 - High variability in path lengths

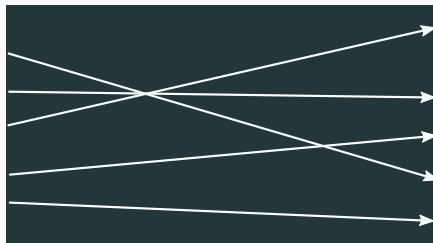
4. MIX NETWORKS

- Problem: How to send messages anonymously
- Sender and receiver anonymity, depending on the system

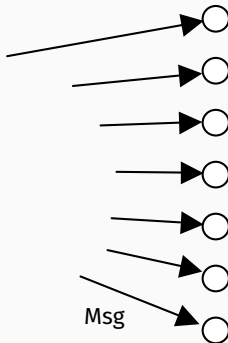
senders



mix server



recipients



⁸D. L. Chaum, "Untraceable Electronic Mail, Return Addresses, and Digital Pseudonyms," *Commun. ACM*, vol. 24, no. 2, pp. 84–90, Feb. 1981. doi: 10.1145/358549.358563. [Online]. Available: <http://doi.acm.org/10.1145/358549.358563>.

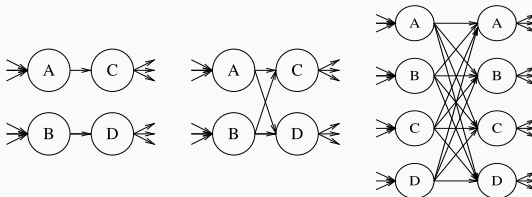
FIFO MIXES: A NAIVE APPROACH TO MIX NETWORKS

- The mix sends out messages in the order they arrived
- Adversary:
 - Observes flow of messages into and out of the mix
 - Simple traffic analysis attack: assign outputs in the order of inputs
 - Minor challenge: observation may start while mix is already operating (how to match the first input/output pair?)
- How can mixes improve resistance to traffic analysis?
 - Mixes can delay and reorder packets
 - Mixes can inject traffic
- In addition: mixes cannot send out unaltered messages
 - Adversary can match bit patterns
 - Mix needs to add cryptographic mechanism to unlink incoming/outgoing messages

- Firing condition: when does the mix fire?
 - Every n messages, every t seconds?
- Batching strategy: how does the mix release messages?
 - Pool of stored messages
 - Release all messages at once, retain some (which ones?) until the next round?

DESIGN STRATEGIES FOR MIX NETWORKS⁹

- What if the mix is not honest?
 - Use more than one mix!
 - Mix cascades: fixed sequence of mixes (challenge: load balancing)
 - Free routing: random sequence of mixes (security depends on length of sequence)



- What if there are not enough other messages?
 - If adversary can block incoming messages: flood the mix with own messages, break anonymity of target user ($n - 1$ attack)

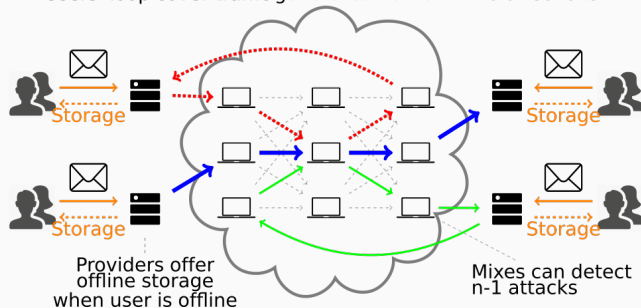
⁹R. Dingledine, V. Shmatikov, and P. Syverson, "Synchronous Batching: From Cascades to Free Routes," in *Privacy Enhancing Technologies*, ser. Lecture Notes in Computer Science 3424, D. Martin and A. Serjantov, Eds., Springer Berlin Heidelberg, Jan. 2005, pp. 186–206. [Online]. Available: http://link.springer.com/chapter/10.1007/11423409_12.

- Anonymity properties: sender and receiver anonymity
- Servers: dedicated infrastructure
- Adversary:
 - Internal passive adversary reduces size of the anonymity set
 - Internal active adversary can break anonymity, e.g, $n - 1$ attack
- Performance:
 - Depends on the design
 - Mix cascades and free routing introduce delays
 - Batching strategy and firing condition may introduce delays and additional load

MIX NETWORKS IN THE 2010S: LOOPIX¹⁰

- Cover traffic, Poisson mixing (short independent delays) provide sender/receiver anonymity and unobservability
- Traffic analysis resistance against global passive adversary
- Latency: order of seconds; capacity: >300 messages per second

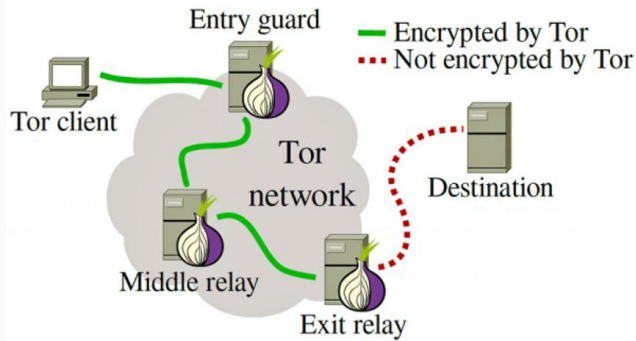
Users' loop cover traffic generates traffic in two directions



¹⁰A. M. Piotrowska, J. Hayes, T. Elahi, et al., "The Loopix Anonymity System," in *26th USENIX Security Symposium (USENIX Security 17)*, 2017, pp. 1199–1216. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity17/technical-sessions/presentation/piotrowska>.

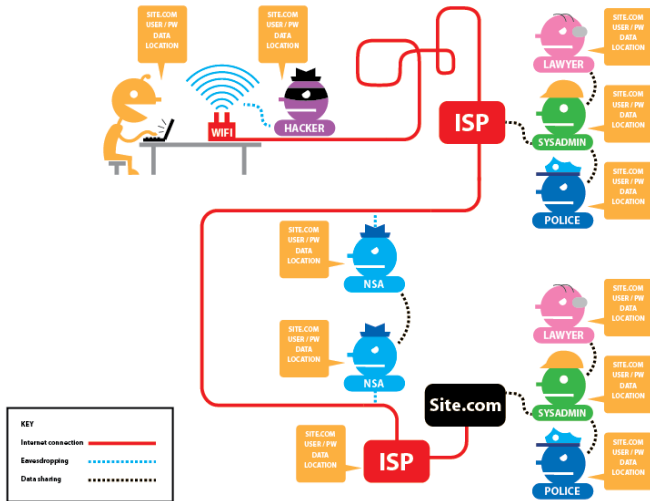
5. ONION ROUTING

- Problem: How to send data streams anonymously
- Sender and receiver anonymity, depending on the system
- Example: The Onion Router (Tor)

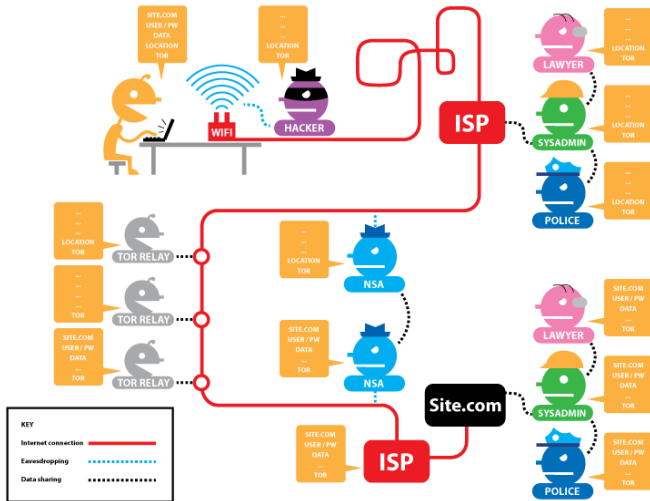


¹¹R. Dingledine, N. Mathewson, and P. Syverson, "Tor: The Second-generation Onion Router," in *13th USENIX Security Symposium (USENIX Security 04)*, San Diego, CA, USA: USENIX Association, Aug. 2004. [Online]. Available: <http://dl.acm.org/citation.cfm?id=1251375.1251396>.

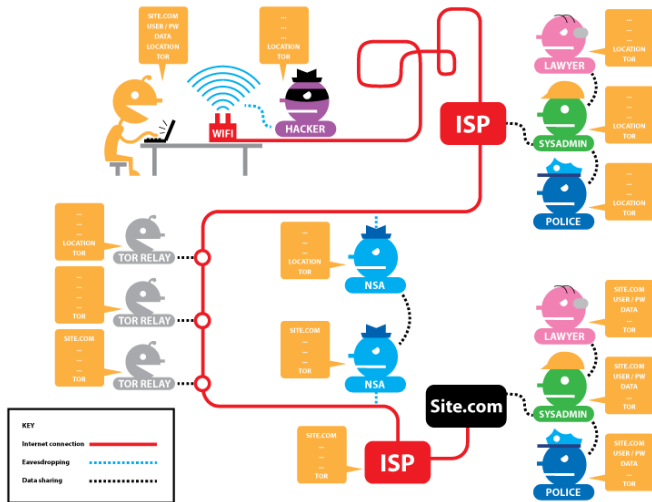
EXAMPLE: NORMAL WEB BROWSING

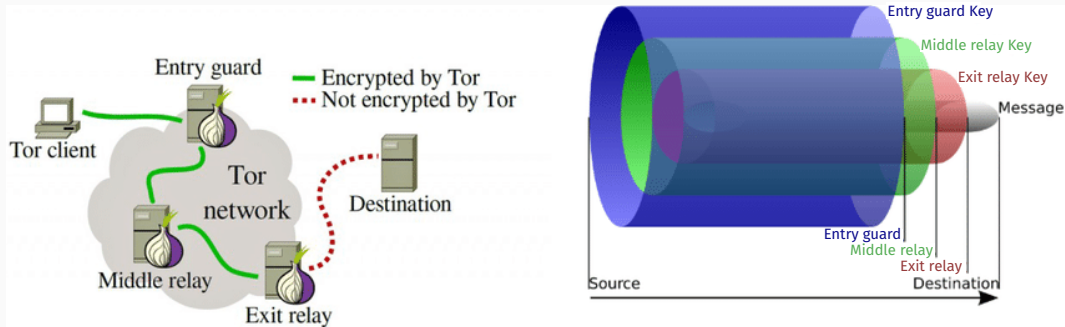


EXAMPLE: ANONYMOUS WEB BROWSING VIA ONION ROUTING



EXAMPLE: ANONYMOUS WEB BROWSING VIA ONION ROUTING + HTTPS

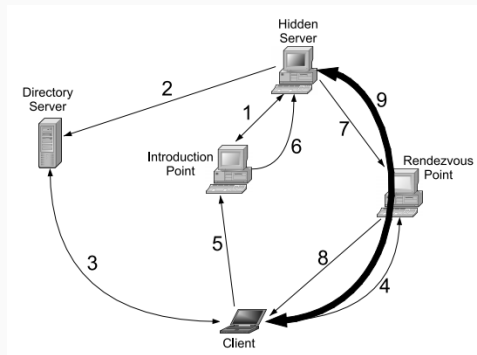




¹²E. Filiol, M. Delong, and J. Nicolas, "Statistical and combinatorial analysis of the TOR routing protocol: Structural weaknesses identified in the TOR network," *Journal of Computer Virology and Hacking Techniques*, vol. 16, no. 1, pp. 3–18, Mar. 2020. DOI: 10.1007/s11416-019-00334-x. [Online]. Available: <https://doi.org/10.1007/s11416-019-00334-x>.

- Directory servers advertise available onion routers (ORs)
- Clients use a SOCKS proxy to tunnel TCP connections through Tor
- Each TCP connection uses a circuit, built incrementally by clients
 - Select 3 ORs
 - Negotiate session key (Diffie-Hellman handshake) with first OR
 - Negotiate session keys with second/third OR through first/second OR
 - Second and third OR never see the client's real network address
- Sending packets:
 - Client encrypts packet with three session keys
 - Each OR peels off one *onion layer* (decrypts with their session key)
 - Return packets are similar: each OR encrypts with its session key, client decrypts all

- Hidden services: (web) servers only reachable through the Tor network (the “dark web”)
 - Hidden server selects one or more ORs as introduction point (IP), builds circuit to each
 - Directory server publishes IPs
- Client:
 - Selects an OR as rendezvous point (RP), builds circuit to this OR
 - Contacts IP to request that hidden server contacts the RP
 - Hidden server builds circuit to RP
 - Communication over two Tor circuits!



¹³L. Overlier and P. Syverson, “Locating hidden servers,” in *2006 IEEE Symposium on Security and Privacy (S&P’06)*, May 2006, 15 pp.–114. DOI: 10.1109/SP.2006.24.

ATTACKS ON TOR

User client



Tor network



Web server



ATTACKS ON TOR

User client



Tor network



Web server



ATTACKS ON TOR

User client



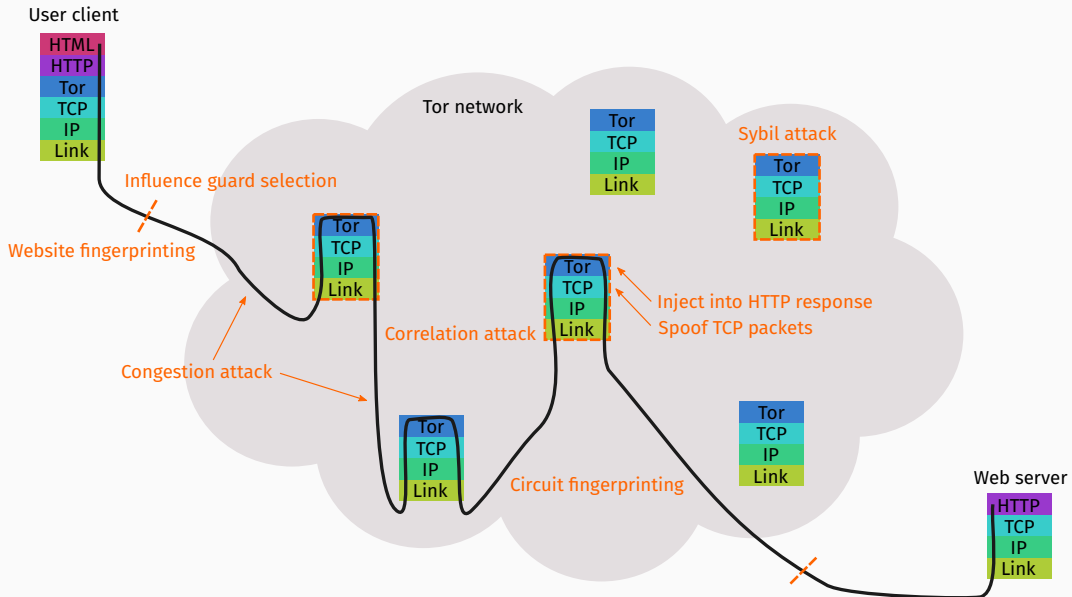
Tor network

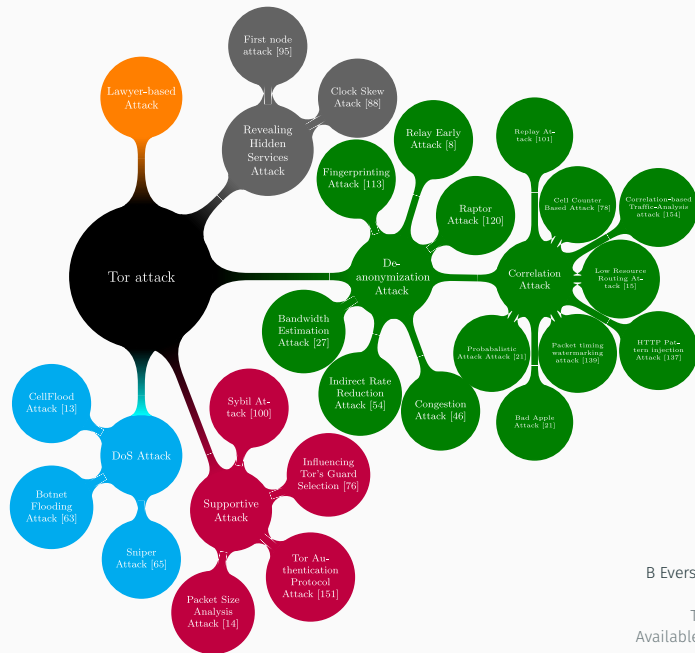


Web server



ATTACKS ON TOR





B Evers, J Hols, E Kula, *et al.*, "Thirteen Years of Tor Attacks," Delft University of Technology, Tech. Rep., 2019. [Online]. Available: <https://github.com/Attacks-on-Tor/Attacks-on-Tor>

- Anonymity properties: sender and receiver anonymity
- Servers: dedicated infrastructure, users can contribute if they want
- Adversary:
 - Global passive adversary can break anonymity
 - Many attacks proposed also for less powerful adversaries, but lower success rates
 - Tor protocol and client are tweaked often to mitigate attacks
- Performance:
 - Depends on bandwidth and latency of intermediate nodes
 - Note that geographic location may influence latency!
 - In best case, feasible for video streaming

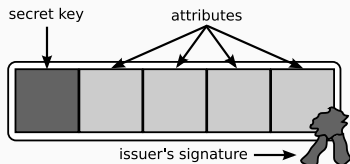
- Design strategies for successful anonymous communication systems:
 - Re-routing
 - Encryption
 - Dummy/cover traffic
- Many existing attacks on anonymous communication systems
 - New systems should resist at least all the known attacks

6. PRIVACY-PRESERVING AUTHENTICATION

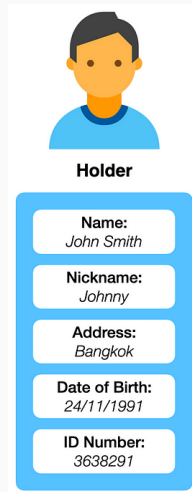
- Authentication:
 - Identify who the user is
 - Password, biometrics, tokens
 - In the real world: identity cards, passports
- Authorization:
 - Has this user paid for the streaming service?
 - Is this user old enough to access this service?
 - Is this a real user and not a bot?
- Services don't really need to know *identities* for authorization!
- Idea: authorize users without performing full user identification

ATTRIBUTE-BASED CREDENTIALS¹⁴

- A credential contains a number of attributes
- The issuer verifies correctness of attributes, signs the credential



- The user can “show the credential” to a verifier
 - Or more correctly: prove that they possess the credential
 - Selectively disclose attributes or their properties



¹⁴P. Vullers and G. Alpár, “Efficient Selective Disclosure on Smart Cards Using Idemix,” in *Policies and Research in Identity Management*, ser. IFIP Advances in Information and Communication Technology 396, S. Fischer-Hübner, E. de Leeuw, and C. Mitchell, Eds., Springer Berlin Heidelberg, Apr. 2013, pp. 53–67. DOI: 10.1007/978-3-642-37282-7_5. [Online]. Available: http://link.springer.com/chapter/10.1007/978-3-642-37282-7_5.

ATTRIBUTE-BASED CREDENTIALS: SELECTIVE DISCLOSURE

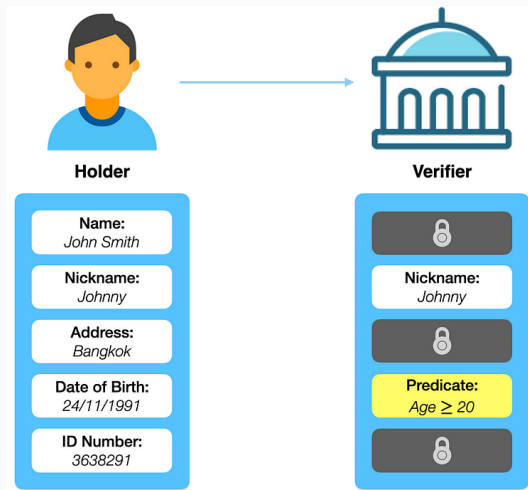
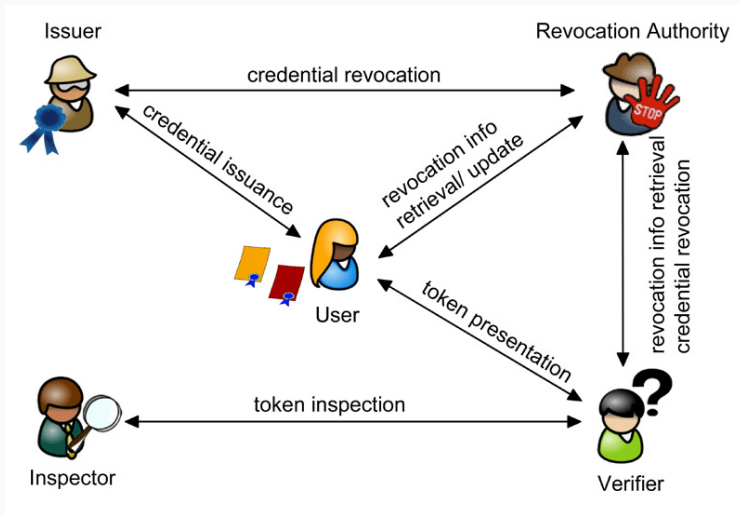


Image source: <https://medium.com/finema/anonymous-credential-part-1-brief-overview-and-history-c6679034c914>

USAGE OF ATTRIBUTE-BASED CREDENTIALS¹⁵



¹⁵J. Camenisch, M. Dubovitskaya, A. Lehmann, et al., "Concepts and Languages for Privacy-Preserving Attribute-Based Authentication," in *IFIP Working Conference on Policies and Research in Identity Management (IDMAN)*, ser. IFIP Advances in Information and Communication Technology, S. Fischer-Hübner, E. de Leeuw, and C. Mitchell, Eds., vol. 396, London, UK: Springer Berlin Heidelberg, Apr. 2013, pp. 34–52. doi:

- Unforgeability
 - Only the issuer can produce valid credentials
- Selective disclosure
 - Users can hide irrelevant attributes
- Issuer unlinkability
 - The issuer cannot recognize credentials it has previously issued
 - The issuer cannot link showings of the credentials to user identities!
- Verifier unlinkability
 - Verifiers cannot link two consecutive showings of the same credential

- Combination of signatures, cryptographic commitments, zero-knowledge proofs
 - Idemix (IBM): Camenisch-Lysyanskaya signatures
 - UProve (Microsoft): Brands signatures
- Credential: signature on the user's attributes
- Pseudonyms: cryptographic commitment to the user's secret key
- Presentation tokens: zero-knowledge proof that user (pseudonym) possesses a credential with the required attributes (non-interactive version through Fiat-Shamir transform)
- Revocation: signed revocation lists or short-lived credentials
- Inspection: verifiable encryption

¹⁶J. Camenisch, M. Dubovitskaya, A. Lehmann, et al., "Concepts and Languages for Privacy-Preserving Attribute-Based Authentication," in *IFIP Working Conference on Policies and Research in Identity Management (IDMAN)*, ser. IFIP Advances in Information and Communication Technology, S. Fischer-Hübner, E. de Leeuw, and C. Mitchell, Eds., vol. 396, London, UK: Springer Berlin Heidelberg, Apr. 2013, pp. 34–52. doi: 10.1007/978-3-642-37282-7_4. [Online]. Available: http://link.springer.com/chapter/10.1007/978-3-642-37282-7_4.

- Service providers have to participate:
 - Users can hide irrelevant attributes, but if server only provides the service if user supplies their “name” and “date of birth” attributes, users are left with the same old choice: privacy or service
 - Could attribute requirements be regulated...?
- Uptake is limited despite efficient implementations on smart cards by IBM and Microsoft
 - Why no adoption by high-profile issuers?

1. Anonymous communication
2. Dining cryptographers
3. Crowds
4. Mix networks
5. Onion routing
6. Privacy-preserving authentication